

실습 1. Firewall 의 rich-rule로 규칙 만들기

블랙리스트 기반의 설정에서 1.1.2.0/24 대역만 웹서버 차단하기

1. 블랙리스트 기반 = 기본값 허용(ACCEPT)

기본 허용에서 차단하는 규칙을 추가하므로
별도의 전역 허용 설정은 필요없음 (총 1개)

2. 규칙 만들기

모든 옵션을 설정한 버전

firewall-cmd ₩	# firewalld 제어 명령어
--permanent ₩	# 설정을 영구적으로 저장
--zone=public ₩	# public 존에 규칙 적용
--add-rich-rule='rule ₩	# public 존에 rich rule 추가
priority="100" ₩	# rich rule 평가 우선순위(낮을수록 먼저)
family="ipv4" ₩	# IPv4 패킷에만 적용
source address="1.1.2.0/24" ₩	# 1.1.2.0/24 출발지 트래픽만 매칭
destination address="0.0.0.0/0" ₩	# 모든 목적지 대상
service name="http" ₩	# HTTP 서비스(TCP 80) 트래픽
log prefix="HTTP_DROP" level="warning" ₩	# 차단 패킷 로그 기록
limit value="30/m" ₩	# 분당 30회로 로그/규칙 적용 제한
drop'	# 매칭된 패킷 차단

하지만 굳이 다 쓸 필요는 없겠다?!

필요한 옵션만 적용한 버전

```
firewall-cmd ₩
--permanent ₩
--add-rich-rule='rule ₩
family="ipv4" ₩
source address="1.1.2.0/24" ₩
service name="http" ₩
log prefix="HTTP_DROP" ₩
drop'
```

규칙을 추가 완료했다면 설정 적용하기

```
firewall-cmd --reload
```

(systemctl reload firewalld와는 다릅니다! - 재시작 기능)

실습 2. 이번엔 UFW 에서 rich-rule방식으로 규칙 만들기

블랙리스트 기반의 설정에서 1.1.2.0/24 대역만 웹서버 허용하기

1. UFW 로그 활성화 확인, 기본 허용 확인

```
ufw logging on          # 로그 활성화
ufw default allow incoming  # 인바운드 기본 허용
```

2. 규칙 만들기

여기선 1.1.2.0/24 대역만 허용하므로
전체 차단 규칙 이전에 예외 규칙을 별도로 만들어야 한다.

- 1 – 예외 규칙
- 2 – 전체 규칙

● 예외 규칙 (1.1.2.0/24 대역만 웹서버 허용)

ufw allow ₩	# 허용
in ₩	# 인바운드 트래픽
on any ₩	# 모든 인터페이스
proto tcp ₩	# TCP 프로토콜
from 1.1.2.0/24 ₩	# 출발지가 1.1.2.0/24 대역
to any port 80	# 목적지가 포트 80인 경우

여기서 생략하면?

ufw allow from 1.1.2.0/24 to any port 80

● 전체 규칙 (나머지 대역은 차단)

ufw deny ₩	# 차단
in ₩	
on any ₩	
proto tcp ₩	
from any ₩	# 모든 출발지 IP 대역
to any port 80	

이것도 생략하면

ufw deny to any port 80

진짜 Uncomplicated FireWall 이죠?

실습 3. Firewall에서 nmap 탐지, 차단 규칙 만들기

칼리에서 nmap으로 보내는 ACK 스캔(-sA) 을 탐지하고 차단

ACK 스캔 (-sA):

TCP 연결의 3-Way Handshake 과정을 따르지 않고,
무작정 **ACK 플래그만 설정된 패킷을 전송한다**

일반적인 상황:

ACK 패킷은 이전에 연결이 수립된 상태에서만 와야 하는데,
갑자기 ACK가 오면 대상 호스트는 "나는 이런 연결을 한 적이 없는데?" 라며
RST(Reset) 패킷을 반환함

방화벽이 있는 경우:

방화벽이 해당 포트를 차단하고 있다면
ACK 패킷을 버리거나(Drop), ICMP 에러 메시지를 보냅니다.

1. 타겟에 방화벽이 있는 것이 확실할 때.
2. 어떤 포트가 "통과 가능한 구멍"인지 찾아야 할 때
3. 방화벽 설정의 허점(Stateless 규칙 등)을 찾아내어 침투 경로를 설계할 때
등등 방화벽의 상태와 허점을 조사할 때 사용하는 nmap의 포트 스캔이다

그렇다면 이걸 firewalld에 이걸 탐지하고 차단하는 규칙을 만들 시간이다

TCP에서 기존 세션이 없을 때 SYN이 온다면 NEW,
기존 세션이 있는 상태에서 ACK가 온다면 ESTABLISHED,
그러나 기존 세션이 없는데 ACK가 온다면 INVALID로 판정

1. 스캔 탐지 규칙 (IDS)

```
firewall-cmd --permanent₩  
  --add-rich-rule='rule ₩  
protocol value="tcp" ₩  
tcp-flags ack ack ₩  
ctstate="INVALID" ₩  
log prefix="NMAP_ACK_SCAN " level="info" ₩  
accept'                                # 탐지만 하고 흐름 유지
```

2. 스캔 차단 규칙 (IPS)

```
firewall-cmd --permanent₩  
  --add-rich-rule='rule ₩  
protocol value="tcp" ₩  
tcp-flags ack ack ₩  
ctstate="INVALID" ₩  
log prefix="NMAP_ACK_SCAN " level="info" ₩  
drop'
```

3. nmap에서 스캔 전송후 로그 확인하기

```
tail -f /var/log/messages | grep "NMAP_ACK_SCAN" (실시간)
```

```
tail -n 50 /var/log/messages | grep "NMAP_ACK_SCAN" (50줄 이내)
```

4. 실습 후 규칙 삭제하기

firewall-cmd --list-rich-rules # 현재 설정된 리치 룰 목록 확인

확인한 규칙에서 --add-rich-rule='rule~~~' 부분을
--**remove**-rich-rule='rule~~~' 로 변경해서 삭제하기

firewall-cmd --reload # 삭제한 내용 적용하기

firewall-cmd --list-all # 마지막으로 목록 조회로 확인